

VAPT ASSESSMENT PROFILE

API Security Risk Analysis

Technical Vulnerability Mapping & Boundary Evaluation

Target Environment: **SaaS Endpoint Proxy** (<https://reqres.in>)

Audit Framework: **OWASP API Security Top 10 Core Methodology**

Assessment Context: **Cyber Security Program — Task 3**

MEGHANA YADAV
TECHNICAL INTERN

| AUDIT OBJECTIVE & SCOPE

Protecting modern enterprise distributed network frames requires comprehensive boundary tracking to capture edge filtering defects before exploitation chains mature.

This read-only technical assessment isolates API endpoint routing controls, schema footprints, and rate-limiting enforcement thresholds from an active client framework perspective.

Target Gateway:	https://reqres.in
Assessment Scope:	Public-facing User Routing Architectures (`/api/users`)
Technical Audit Focus:	Response Parameter Integrity & Transaction Control Constraints

| METHODOLOGY & VERIFICATION TOOLS

Evaluations were performed utilizing structured non-disruptive techniques to document routing controls without altering live cloud cluster components.

Postman Engine

Orchestrated isolated client runtime calls to issue token properties, modify header contexts, and audit API gateway resolution maps.

OWASP API Framework

Cross-referenced live behavioral logs directly against global application logic risk paradigms to categorize baseline defensive parameters.

JSON Schema Analysis

Inspected single-object data payload distributions to audit parameter definitions and ensure background structural variables remain hidden.

| EXECUTIVE SUMMARY

Overall System Posture: **VULNERABLE**

The boundary security audit maps an explicit high-severity structural defect within traffic-limiting components, contrasted by robust perimeter authentication gates tracking base verification lines.

While unauthorized scraping access is blocked across general directory endpoints, the lack of continuous request limitations on active resource profiles exposes underlying microservices to high-velocity automation scripts and denial attacks.

01

HIGH RISK DEFECT LOGGED

02

DEFENSIVE PARAMETERS PASSED

| 01. BROKEN AUTHENTICATION ENFORCEMENT

LOW (SECURED) OWASP API2:2023 — Broken Authentication

```
GET /api/users?page=2 → HTTP 401 Unauthorized → {"error": "missing_api_key"}
```

Technical Analysis: The gateway blocks anonymous browser connections. Resource nodes open paths only when matching headers successfully validate active signature string definitions.

Business Impact: Strong edge perimeter enforcement. Prevents adversarial crawlers and automated scraper bots from gathering employee identity structures or mining dataset lines.

Verification Signature: Logged and indexed under configuration file Evidence_CS-01.

| 02. PAYLOAD DATA MINIMIZATION COMPLIANCE

LOW (SECURED) OWASP API3:2023 — Excessive Data Exposure

```
GET /api/users/2 → Response Filter Schema Reflection Compliance
```

Technical Analysis: Query analytics against active user profiles confirm JSON response arrays limit field definitions strictly to presentation variables (id, email, first_name, last_name, avatar).

Business Impact: Zero database architecture spill. No administrative flags, database relationship coordinates, or system tracking parameters are leaked to transit streams.

Verification Signature: Logged and indexed under configuration file Evidence_CS-02.

| 03. UNRESTRICTED RESOURCE CONSUMPTION

HIGH (VULNERABLE) OWASP API4:2023 — Unrestricted Resource Consumption

GET /api/users/2 → Request Flooding (15 Actions / 5s) → Continuous HTTP 200 OK (378ms)

Technical Analysis: The gateway completely lacks transactional constraint filters. Inbound automated traffic runs sequentially without triggering cooling thresholds or forcing an HTTP 429 restriction block.

Business Impact: Severe infrastructure availability exposure. Malicious loops can execute unbounded queries, exhausting cluster resources, inflating SaaS platform compute costs, and risking broad service denial.

Verification Signature: Logged and indexed under configuration file Evidence_CS-03.

RISK CLASSIFICATION MATRIX

VULNERABILITY CHARACTERISTIC	THREAT SEVERITY	REMEDIATION PRIORITY	ENGINEERING FEASIBILITY
Unrestricted Resource Consumption	HIGH	Immediate Horizon	High Feasibility (Gateway Level Rule)
Broken Authentication Exposure	LOW	Pass (Maintained)	Validated Secure (Edge Layer Enforced)
Excessive Data Schema Leakage	LOW	Pass (Maintained)	Validated Secure (Payload Level Filtered)

| REMEDIATION IMPLEMENTATION ROADMAP

Deploying defensive policies directly at proxy gateways resolves structural vulnerabilities without altering baseline application architectures.

Phase 1: Rate Throttling

Configure strict sliding window constraints (max 60 actions/minute per token profile) inside edge proxies to trigger immediate HTTP 429 errors.

Phase 2: Bearer Migration

Transition from passing static parameters to short-lived, cryptographically signed JSON Web Tokens (JWT) handled within Authorization: Bearer headers.

Phase 3: Payload Inspection

Enforce strict character count and payload geometry evaluation rules directly at the perimeter layer to instantly discard deep malicious queries.

| ASSESSMENT CONCLUSION

The boundary security audit of target routes establishes clear operational risks sitting directly alongside a well-maintained data schema filter paradigm.

Because the core unrestricted resource consumption exposure lies strictly within traffic management configurations rather than complex back-end source code frameworks, deploying the remediation steps will instantly eliminate system risks with zero latency overhead.

PROJECT REMEDIATION STATUS: HIGHLY FEASIBLE

*"Security is not a final static product or checkpoint,
but a continuous mitigation process."*

— **INDUSTRY OPERATIONAL MAXIM**

VAPT SECURITY AUDIT // REQRES 11

End of Report

Standing by
for strategic
infrastructure
security
alignment
questions.

MEGHANA YADAV

TECHNICAL INTERN // CYBER SECURITY